

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Calificación Sistemática de 20+ Métricas CRM

Versión: 2.0 | Fecha: Enero 2026 | Clasificación: Público

INTRODUCCIÓN

Esta matriz evalúa cada métrica CRM contra **9 criterios PRAGMATIC** en escala 0-5.

Resultado: Score PRAGMATIC 0.0-5.0 que determina recomendación (rechazar/mejorar/implementar).

SECCIÓN 1: INDICADORES GOBERNANZA

Métrica 1.1: RAS (Risk Appetite Statement) Documentado

Criterio	Score	Justificación
P — Predictivo	3/5	RAS no predice directamente incidentes; es "baseline" para decisiones futuras
R — Relevante	5/5	DORA Art 11, NIS2, NIST Govern — crítico junta
A — Accionable	4/5	IF no RAS THEN rechazar inversiones no-aligned
G — Genuino	5/5	Documento verificable; no gaming posible
M — Significativo	4/5	Existe RAS = desiciones gobernanza mejoran; Impacto documentado
A — Preciso	4/5	Definición clara: "RAS documento v.X dated Y firmado Z"
T — Oportuno	5/5	Estático (anual revision); no requiere actualización frecuente
I — Independiente	5/5	No depende otras métricas; standalone
C — Rentable	5/5	Bajo costo: documento + reunión junta
PRAGMATIC Score	4.4/5	✓✓ Fuerte; Implementar
Recomendación	✓	Métrica CORE; baseline gobernanza obligatoria

Métrica 1.2: CISO Reporta CEO (Línea Directa)

Criterio	Score	Justificación
P — Predictivo	2/5	Débil predictor incidentes; más sobre estructura org
R — Relevante	5/5	DORA exige designación formal; visibilidad ejecutiva
A — Accionable	2/5	Si "no" → OK, actionable; si "sí" → fin metric
G — Genuino	5/5	Verificable org chart; no ambigüedad
M — Significativo	3/5	Correlación débil riesgo operacional; governance signal
A — Preciso	5/5	Definición: "Reporting line CISO – CEO en org chart"
T — Oportuno	5/5	Estático; cambios infrecuentes
I — Independiente	4/5	Correlacionado RAS; acceptable overlap
C — Rentable	5/5	Costo zero: verificación org chart
PRAGMATIC Score	3.8/5	✓ Aceptable; Implementar
Recomendación	✓	Métrica estructural; no es KPI performance pero sí governance gate

SECCIÓN 2: INDICADORES CUANTIFICACIÓN (FAIR)

Métrica 2.1: ALE Top 5 Riesgos (en €)

Criterio	Score	Justificación
P — Predictivo	4/5	Correlación demostrada: ALE ↑ = breach severity probable ↑
R — Relevante	5/5	CFO entiende €; DORA exige quantificación; ROI-critical
A — Accionable	5/5	IF ALE > budgeted control THEN reallocate funds
G — Genuino	3/5	FAIR estimates subjetivas; pero transparentes si GQM bien documentado
M — Significativo	5/5	Material diferencia en decisiones: €5M vs €500K → different priority
A — Preciso	3/5	FAIR metodología clara; pero resultados vary consultant → consultant
T — Oportuno	3/5	FAIR típicamente anual; no monthly tracking factible
I — Independiente	4/5	Depende vulnerability scanning (acceptable relationship)
C — Rentable	2/5	FAIR assessment costly: €50-100K consulting típico
PRAGMATIC Score	3.9/5	✓ Acceptable; Implementar con caveats
Recomendación	✓	CORE métrica; pero costo importante; baseline anual mínimo

Métrica 2.2: ROI Control Investment (%)

Criterio	Score	Justificación
P — Predictivo	4/5	ROI positivo predice effective control; precedente industrial
R — Relevante	5/5	CFO adora ROI; criterio decisión presupuesto
A — Accionable	5/5	IF ROI <100% THEN reconsider investment
G — Genuino	4/5	Cálculo objetivo SI ALE bien cuantificada; vulnerable si FAIR débil
M — Significativo	5/5	Alto material: ROI 500% vs ROI 50% → completely different story
A — Preciso	4/5	Fórmula clara: $(\text{Savings} - \text{Cost}) / \text{Cost} \times 100\%$
T — Oportuno	4/5	Calculable cuando decision made; update annual
I — Independiente	2/5	Altamente dependiente ALE (no independent)
C — Rentable	4/5	Colección Excel-based; bajo costo
PRAGMATIC Score	4.2/5	✓✓ Fuerte; Implementar
Recomendación	✓	CORE métrica; dependency on ALE acceptable

SECCIÓN 3: INDICADORES SOC/SIEM

Métrica 3.1: MTTD (Mean Time To Detect) — Minutos

Criterio	Score	Justificación
P — Predictivo	5/5	MTTD ↓ = breach damage ↓; correlación IBM DBIR documentada
R — Relevante	5/5	DORA Art 19; CFO interesado (breach cost link); CISO KPI standard
A — Accionable	5/5	IF MTTD >1h THEN escalate incident review; clear trigger
G — Genuino	5/5	Timestamp objective; imposible gaming
M — Significativo	5/5	Cada 10 min reduction = €500K+ saved (cambio material)
A — Preciso	5/5	Definición operacional: log timestamp — incident timestamp
T — Oportuno	5/5	Real-time availability; dashboard daily
I — Independiente	4/5	Algo correlación MTTR (incidente lifecycle); acceptable
C — Rentable	4/5	Auto-extract SIEM; <€5K setup costo
PRAGMATIC Score	4.7/5	√√√ Óptimo; Implementar ASAP
Recomendación	✓	TOP-1 métrica SOC; excellence level

Métrica 3.2: MTTR (Mean Time To Respond) — Horas

Criterio	Score	Justificación
P — Predictivo	5/5	MTTR ↓ = data exfiltration prevented; proven correlation
R — Relevante	5/5	DORA <4h requirement; CFO interesado; board visibility
A — Accionable	5/5	IF MTTR >SLA THEN incident review + root cause
G — Genuino	5/5	Incident ticket timestamp; auditable
M — Significativo	5/5	Material diferencia: <4h vs >24h = 10x data loss
A — Preciso	4/5	Definición clara pero "response start" can vary (detection vs action)
T — Oportuno	5/5	Tracked incident management system; real-time
I — Independiente	4/5	Corr MTTD; but MTTR es "second half" lifecycle
C — Rentable	5/5	Extraído incident ticketing existente; costo zero
PRAGMATIC Score	4.6/5	√√√ Óptimo; Implementar ASAP
Recomendación	✓	TOP-2 métrica; regulatory requirement DORA

Métrica 3.3: False Positive Rate SIEM (%)

Criterio	Score	Justificación
P — Predictivo	3/5	No predice incidentes; measure of alert quality
R — Relevante	4/5	Relevante SOC (alert fatigue); menos relevante CFO
A — Accionable	4/5	IF FPR >10% THEN tune SIEM rules
G — Genuino	3/5	"False positive" definición varia (true negative? miscategorized?)
M — Significativo	3/5	Impacto moderado; más sobre operacional efficiency que risk
A — Preciso	2/5	Definición ambigua; what counts as "false"?
T — Oportuno	4/5	Daily calculation possible
I — Independiente	5/5	Standalone metric
C — Rentable	4/5	Extraído SIEM; bajo costo
PRAGMATIC Score	3.6/5	✓ Acceptable; Implementar with caution
Recomendación	⚠	Métrica válida pero secundaria; no es core KPI

SECCIÓN 4: INDICADORES VULNERABILIDADES

Métrica 4.1: % Vulnerabilidades Críticas Parcheadas <7 Días

Criterio	Score	Justificación
P — Predictivo	5/5	Patching velocity ↑ = breach probability ↓; documentado academic literature
R — Relevante	5/5	NIS2, ISO 27001, NIST exigen patching SLA; CEO interesado
A — Accionable	5/5	IF <95% THEN escalate patch management; SLA violation
G — Genuino	5/5	Patch timestamp verifiable; no gaming
M — Significativo	5/5	Material: unpatched critical vuln = compromise probable en semanas
A — Preciso	4/5	Definición clara; "crítico" = CVSS 9+ o exploited in wild
T — Oportuno	4/5	Weekly tracking feasible; monthly reporting standard
I — Independiente	4/5	Depende scanning; but acceptable dependency
C — Rentable	4/5	Auto-extract vulnerability management tool; bajo costo
PRAGMATIC Score	4.6/5	√√√ Óptimo; Implementar ASAP
Recomendación	✓	TOP-3 métrica; regulatory + operational critical

Métrica 4.2: Scanning Frequency (días)

Criterio	Score	Justificación
P — Predictivo	3/5	Frequency no predice vulns; es prerequisite detección
R — Relevante	4/5	Relevante CISO/security ops; menos CEO
A — Accionable	3/5	IF frequency <1/week THEN increase scanning
G — Genuino	5/5	Verificable; no gaming
M — Significativo	3/5	Impacto indirecto vía vulnerability detection latency
A — Preciso	5/5	Definición clara: scan schedule in tool
T — Oportuno	5/5	Real-time available
I — Independiente	5/5	Standalone
C — Rentable	5/5	Costo zero: scheduler config
PRAGMATIC Score	4.0/5	✓ Aceptable; Implementar
Recomendación	⚠	Métrica válida pero "input" (frequency) no "output" (results); considerar como control attribute vs KPI

SECCIÓN 5: INDICADORES AWARENESS

Métrica 5.1: Phishing Click Rate (%)

Criterio	Score	Justificación
P — Predictivo	4/5	Click rate ↑ = breach probability ↑ (human compromised); documentado
R — Relevante	5/5	88% breaches human-caused (Verizon); CEO, CISO, auditor interesados
A — Accionable	5/5	IF >5% THEN increase training frequency
G — Genuino	4/5	Simulation-based; puede ser gaming (employees know it's test)
M — Significativo	5/5	Material: <3% vs 15% = very different security posture
A — Preciso	4/5	Definición clara: % usuarios clicked link in simulation
T — Oportuno	4/5	Monthly simulations feasible; trending trackable
I — Independiente	4/5	Depende training adoption (acceptable)
C — Rentable	3/5	Simulation tools cost €30K-50K anual; pero justified ROI
PRAGMATIC Score	4.3/5	✓✓ Fuerte; Implementar
Recomendación	✓	TOP-4 métrica; human risk critical

Métrica 5.2: Phishing Report Rate (%)

Criterio	Score	Justificación
P — Predictivo	3/5	Reporting ↑ = detection ↑ (indirect); débil predictor breach
R — Relevante	4/5	Relevante seguridad culture; menos relevante CFO
A — Accionable	4/5	IF <20% THEN engagement campaign needed
G — Genuino	4/5	Sistema email reports; pero peut be false reports (crying wolf)
M — Significativo	3/5	Impacto indirecto vía early detection; no direct risk reduction
A — Preciso	4/5	Definición: emails reported / phishing emails deployed
T — Oportuno	5/5	Real-time tracking
I — Independiente	4/5	Depende click rate (acceptable correlation)
C — Rentable	5/5	Auto-extract email system; costo zero
PRAGMATIC Score	3.9/5	✓ Aceptable; Implementar
Recomendación	✓	Métrica válida; cultural indicator más que risk KPI

SECCIÓN 6: INDICADORES COMPLIANCE

Métrica 6.1: GDPR Compliance Score (%)

Criterio	Score	Justificación
P — Predictivo	2/5	Compliance no predice breach; es "hygiene" baseline
R — Relevante	5/5	GDPR legal requirement; auditor, CFO, juez interesados
A — Accionable	5/5	IF <95% THEN gap remediation plan
G — Genuino	3/5	Scoring puede ser subjective (auditor-dependent)
M — Significativo	5/5	Material: sanciones €20M si non-compliant
A — Preciso	3/5	Definición varia auditor → auditor; ambigüedad
T — Oportuno	3/5	Típicamente annual audit; no real-time
I — Independiente	5/5	Standalone assessment
C — Rentable	1/5	Auditoría externa cara: €50- 100K anual
PRAGMATIC Score	3.6/5	✓ Aceptable; Implementar (mandate)
Recomendación	✓	Métrica requerida regulatoria; costo high pero obligatorio

Métrica 6.2: NIS2 Readiness Score (%) — Pre-Transposición

Criterio	Score	Justificación
P — Predictivo	2/5	Predictibilidad baja (regulación aún en transposición España)
R — Relevante	5/5	NIS2 deadline españa Q1 2026; gobierno + empresa critical
A — Accionable	5/5	IF <80% THEN acceleration roadmap
G — Genuino	2/5	Definición aún fluid (transposición nacional TBD)
M — Significativo	5/5	Material: sanciones €10M potential
A — Preciso	2/5	Precisión baja; requirements still being clarified
T — Oportuno	3/5	Puede actualizarse quarterly vía guidance updates
I — Independiente	5/5	Standalone
C — Rentable	2/5	Gap assessment costoso; consultor recomendado
PRAGMATIC Score	3.5/5	✓ Acceptable; Implementar (but monitor changes)
Recomendación	⚠	Métrica importante pero volatilidad alta; revisar quarterly

RESUMEN MATRIZ PRAGMATIC

Ranking Métricas por PRAGMATIC Score

Rango	Métrica	PRAGMATIC	Recomendación
1	MTTD (minutos)	4.7	✓ IMPLEMENTAR INMEDIATO
2	MTTR (horas)	4.6	✓ IMPLEMENTAR INMEDIATO
2	Patch % <7d	4.6	✓ IMPLEMENTAR INMEDIATO
4	Phishing Click Rate	4.3	✓ IMPLEMENTAR
5	ROI Control Investment	4.2	✓ IMPLEMENTAR
6	RAS Documentado	4.4	✓ IMPLEMENTAR
7	ALE Top 5 Risks	3.9	✓ IMPLEMENTAR
8	Phishing Report Rate	3.9	✓ IMPLEMENTAR
9	CISO reporta CEO	3.8	✓ IMPLEMENTAR
10	GDPR Compliance %	3.6	✓ IMPLEMENTAR (MANDATE)
1 1	Scanning Frequency	4.0	⚠ SECUNDARIA
1 2	NIS2 Readiness %	3.5	⚠ MONITOR CAMBIOS
1 3	FP Rate SIEM	3.6	⚠ SECUNDARIA

CONCLUSIÓN

Métricas PRAGMATIC 4.5+ (Excelentes): MTTD, MTTR, Patch % – TOP PRIORIDAD

Métricas PRAGMATIC 4.0-4.5 (Fuertes): RAS, Phishing, ROI – IMPLEMENTAR

Métricas PRAGMATIC 3.5-4.0 (Aceptables): ALE, GDPR, NIS2 – IMPLEMENTAR con caveats

Métricas PRAGMATIC <3.5 (Débiles): FP Rate, Scanning Freq – CONSIDERAR pero no CORE

Fin Matriz PRAGMATIC Completa